CASE STUDY

The Cisco Catalyst SD-WAN Authentication Bypass of 2026 (CVE-2026-20127) and UAT-8616: A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people on the hook here were the network teams who run Cisco Catalyst SD-WAN, the controllers that tell every branch router where traffic goes. On 25 February 2026 they learned that the peering authentication between those controllers could be skipped by anyone who could reach it, that it already had been, and that U.S. federal agencies had about two days to patch [1] [4] [12] (**Confirmed**).

Cisco scored CVE-2026-20127 at CVSS 10.0 and said it was aware of limited exploitation [1] [2] (**Confirmed**). Cisco Talos tied the exploitation to a cluster it calls UAT-8616 and found malicious activity going back at least to 2023 [7] (**Confirmed**). Six national agencies warned the same day of global targeting, CISA issued Emergency Directive 26-03, and the platform went on to draw seven more Known Exploited Vulnerabilities (KEV) entries by the end of September [4] [8] [12] (**Confirmed**). In October Talos named a second actor, UAT-11473, using the same flaw [17] (**Confirmed**).

Key facts at a glance

Field	Value
Product	Catalyst SD-WAN Controller (formerly vSmart), Manager (formerly vManage) and, from 16 Jun 2026, Validator (formerly vBond), in every deployment model [1]
Flaw	Peering authentication bypass; CVSS 3.1 10.0; CWE-287; Cisco bug CSCws52722 [1] [2]
Disclosed	25 Feb 2026, 16:00 GMT; CVE reserved 8 Oct 2025 [1] [3]
Fixed in	20.9.8.2, 20.12.5.3 or 20.12.6.1, 20.15.4.2, 20.18.2.1; no workaround [1]
KEV	Added 25 Feb 2026, due 27 Feb, with CVE-2022-20775 [4]
Actors	UAT-8616 (Talos, high confidence, highly sophisticated, no country named) [7]; UAT-11473 (Talos, October 2026) [17]
Earliest activity	At least 2023, per Talos; "likely began in 2023", per CISA [7] [11]
Victims	None named; rogue peers in reported incidents; one service provider described by Mandiant [9] [16]

Key findings

- **The bug opened the fabric's control plane, not one box.** An unauthenticated attacker could log in as an internal high-privileged account and change SD-WAN fabric configuration through NETCONF [1] (**Confirmed**). Agencies describe a rogue peer added to the fabric as the next step [8] [9] [10] (**Confirmed**).
- **Root likely came from a 2022 bug, by rolling the software back.** Intelligence partners assess the actor likely downgraded the software, exploited CVE-2022-20775, then restored the original version [7] (**Confirmed** as their hedged assessment).
- **The year did not end with one patch.** CVE-2026-20182, a second authentication bypass, was exploited from mid-April, which Talos attributes to UAT-8616 with high confidence [8] [14] [15]; ten other clusters chained three February-patched bugs; and the platform holds nine 2026 KEV entries in all [4] [14] [15] (**Confirmed**).
- **"Since 2023" is a window, not a vector.** No primary says CVE-2026-20127 itself was used in 2023 [7] [11] (**Inferred**).
- **Attribution stays at cluster level.** No government named an actor or a country; the only Volt Typhoon link in the record is an infrastructure overlap Talos draws for UAT-11473, not UAT-8616 [8] [17] [19] (**Confirmed**; news **Reported**).

Top recommendations

1. Run Cisco's fixed releases for CVE-2026-20127 and for CVE-2026-20182, which has its own later builds such as 20.9.9.1 and 20.18.2.2; a February build does not close May's bypass (**Inferred** from [1] [15]).
2. Restrict ports 22 and 830 to known controllers and trusted addresses, and isolate the management VPN 512 [1] [11] (**Confirmed** as Cisco's and CISA's guidance).
3. Hunt back to 2023: validate every control-connection peering event, unknown public-key logins as vmanage-admin, unexplained peers, downgrade-and-reboot sequences and truncated logs [1] [7] [11]

(**Confirmed** as vendor and CISA guidance).

4. Treat any successful root login as compromise and rebuild Manager, Controller and Validator from patched images [11] [12] (**Confirmed** as CISA's direction).
5. Forward logs to an external SIEM, use pairwise keys, replace the self-signed certificate and shorten session timeouts [11] (**Confirmed**); after a compromise, rotate fabric keying material, which KeyDrift was built to collect [17] (**Inferred**).

Scope and method

This brief covers CVE-2026-20127 from the earliest activity the record dates to Cisco's advisory revision of 28 October 2026, with the follow-on SD-WAN CVEs as context. It does not repeat the China-nexus edge-device history in Threat Actors: China or the Volt Typhoon advisory AA24-038A covered in ICS Attacks and Advisories 2024 to 2026 [24]. Tradecraft is described at advisory level; no exploit detail is reproduced.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: Cisco's advisories, the CVE, NVD and KEV records, CISA, FedRAMP and national CERT notices, and the Talos, Mandiant and Censys reports as statements of their own findings
Reported	Known through journalism
Demonstrated	Shown by a researcher's reproduction (Rapid7) or by this study's own check of the library's ATT&CK, CWE, CAPEC and D3FEND files
Inferred	This study's own reasoning from cited facts, labelled where it appears

The ASD's ACSC hunt guide PDF, the ASD alert page and the NSA advisory PDF could not be opened; their content is known here only through the summaries in the CISA, NCSC-NZ and Canadian Cyber Centre alerts.

Part 1: what happened

Date	Event	Sources	Grade
28 Sep 2022	Cisco discloses CVE-2022-20775, an SD-WAN CLI path traversal to root, fixed in 20.6.3, 20.7.2 and 20.8.1	[5]	Confirmed
2023 (at least)	Earliest malicious activity Talos ties to UAT-8616; CISA says activity likely began in 2023	[7] [11]	Confirmed
8 Oct 2025	Cisco reserves CVE-2026-20127	[3]	Confirmed
Late 2025 to Jan 2026	Unauthorized peering to a service provider's SD-WAN Manager; Mandiant says it may have used CVE-2026-20127 or -20182	[16]	Inferred link
25 Feb 2026	Cisco advisory (16:00 GMT), CVE record (16:14 UTC) and NVD entry (17:25 UTC); Cisco also discloses CVE-2026-20122, -20126, -20128, -20129 and -20133, and marks CVE-2022-20775 as attempted-exploited	[1] [2] [3] [5] [13]	Confirmed
25 Feb 2026	Talos names UAT-8616; KEV adds CVE-2026-20127 and CVE-2022-20775; CISA issues ED 26-03 and its Supplemental Direction; six-agency alert and hunt guide; Canada's AL26-004; FedRAMP NTC-0006	[4] [7] [8] [9] [11] [12] [20]	Confirmed
26 Feb 2026	NCSC-NZ alert (07:30 NZ time); ED 26-03 inventory and artifact collection due 23:59 ET	[10] [12]	Confirmed
27 Feb 2026	Cisco revision 1.1 updates the fixed-release table; ED 26-03 patch deadline 17:00 ET; KEV and FedRAMP due date; Censys counts about 600 exposed Managers	[1] [4] [12] [20] [21]	Confirmed
Mar 2026	A public proof of concept appears, which Talos says is wrongly attributed to CVE-2026-20127; Mandiant sees peering possibly using stolen certificate material	[14] [16]	Confirmed
3 Mar 2026	Cisco revision 1.2 updates mitigation; the earliest of ten other clusters is first seen (through 25 Mar)	[1] [14]	Confirmed
5 Mar 2026	Cisco reports active exploitation of CVE-2026-20128 and -20122; ED 26-03 first report due	[12] [13]	Confirmed
11 Mar 2026	ED 26-03 V1 adds log provision to CISA's CLAW by 23 Mar; second report due 12 Mar	[12]	Confirmed
Apr 2026	Mandiant sees zero-day CVE-2026-20245 used for root; a U.S. federal partner finds CVE-2026-20182 exploitation beginning mid-April	[8] [16]	Confirmed
20 Apr 2026	KEV adds CVE-2026-20133, -20122 and -20128	[4]	Confirmed
22 Apr 2026	Cisco reports active exploitation of CVE-2026-20133	[13]	Confirmed
1 May 2026	CISA status report on ED 26-03 due to DHS, ONCD and OMB	[12]	Confirmed

Date	Event	Sources	Grade
14 May 2026	Cisco discloses CVE-2026-20182; Talos attributes its exploitation to UAT-8616 and reports the ten other clusters; KEV adds it; CISA revises the joint alert	[4] [8] [14] [15]	Confirmed
9 and 15 Jun 2026	KEV adds CVE-2026-20245, then CVE-2026-20262	[4]	Confirmed
16 Jun 2026	Cisco revision 2.0 adds Validator to the affected products; Rapid7 publishes a root-cause analysis and proof of concept	[1] [3] [22]	Confirmed; Rapid7 Demonstrated
24 Jun 2026	Mandiant publishes its CVE-2026-20245 report	[16]	Confirmed
30 Sep 2026	KEV adds CVE-2026-76504	[4]	Confirmed
28 Oct 2026	Talos names UAT-11473 and its KeyDrift framework; Cisco revision 2.1 links the post	[1] [17]	Confirmed

Discrepancies in the record

- **Scope grew late.** Validator joined the affected list on 16 June, almost four months after the ED 26-03 patch deadline [1] [12] (**Confirmed**).
- **Version tables are cut differently.** Cisco sends 20.11 users to 20.12.6.1; NVD's CPE ranges treat 20.11 up to before 20.12.5.3 as vulnerable and list 20.12.6 separately [1] [2] (**Confirmed**). Use Cisco's table for upgrade targets (**Inferred**).
- **Three weakness labels for the 2022 bug.** Cisco gives CWE-25, NVD CWE-22, and KEV CWE-25 and CWE-282 [4] [6] (**Confirmed**).
- **"Limited" against "global."** Cisco PSIRT says limited exploitation; the six agencies warn of global targeting [1] [8] (**Confirmed**).

Part 2: the technical record

CVE	Class and weakness	CVSS 3.1	Exploitation and KEV
CVE-2026-20127	Peering authentication bypass, CWE-287	10.0, AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H	Limited, per Cisco; KEV 25 Feb [1] [2] [4]
CVE-2022-20775	CLI path traversal letting an authenticated local attacker run commands as root	7.8	Attempted, Feb 2026; KEV 25 Feb [5] [6]
CVE-2026-20182	Authentication bypass in control-connection handshaking, CWE-287, bug CSCwt50498	10.0	Limited, May 2026; KEV 14 May [4] [15]
CVE-2026-20122, -20128, -20133	Manager flaws found by Cisco's internal testing; KEV lists CWE-648, CWE-257 and CWE-200 [4]	not checked	Exploited Mar to Apr 2026; KEV 20 Apr [4] [13]

The mechanism, at advisory level. Cisco says the peering authentication "is not working properly," so crafted requests let an unauthenticated remote attacker log in as an internal, high-privileged, non-root account and use NETCONF to change the fabric's configuration [1] (**Confirmed**). Rapid7's root-cause analysis describes a forged handshake completion accepted without a cryptographic identity check [22] (**Demonstrated**). The flaw affects every deployment model regardless of configuration: on-premises, Cisco Hosted SD-WAN Cloud, Cisco Managed and FedRAMP [1] (**Confirmed**).

The intrusion sequence. The agencies describe exploitation of CVE-2026-20127 for initial access, a rogue peer added to the fabric, and root access for long-term persistence [8] [9] [10]; CISA's alert names CVE-2022-20775 as the escalation step [8] (**Confirmed**). Partners assess the actor likely reached root by downgrading the software version, then reportedly exploited CVE-2022-20775 and restored the original version [7] (**Confirmed** as their hedged assessment). Cisco said the two CVEs do not depend on one another [19] (**Reported**). CISA's Supplemental Direction says the rogue device appears as a new, temporary, legitimate SD-WAN component [11] (**Confirmed**).

What the actor did after. Talos lists creating, using and deleting accounts; interactive root sessions; unauthorized SSH keys on the vmanage-admin account; clearing or truncating logs and history; unexplained peers; and unauthorized downgrades and upgrades with reboots [7] (**Confirmed**). CISA adds that partners saw lateral movement outside the SD-WAN environment and that the actor removed logs, command history and configurations and tried to stop log forwarding [11] (**Confirmed**).

Detection guidance. Cisco's advisory-level checks are to audit authentication logs for public-key logins as vmanage-admin from unknown addresses, compare source addresses with configured System IPs, validate every control-connection peering event, and collect admin-tech output for a TAC case [1] (**Confirmed**). Talos publishes Snort coverage as SIDs 65938 and 65958 [7], and Rapid7 adds checks for null-IP peers and unexpected vmanage-admin keys [22] (**Confirmed**).

Part 3: who and why

UAT-8616. Talos clusters the exploitation and follow-on activity as UAT-8616, assessed with high confidence to be a highly sophisticated actor, and gives no country [7] (**Confirmed**). In May Talos tied CVE-2026-20182 exploitation to the same cluster with high confidence, called it limited so far, and linked UAT-8616 infrastructure to Operational Relay Box (ORB) networks [14] (**Confirmed**). No source opened for this study states UAT-8616's motive.

The governments. The six-agency alert names no actor, only malicious cyber threat actors targeting SD-WAN globally [8] [10] (**Confirmed**). News coverage noted that no official attributed the activity to a country [19] (**Reported**).

UAT-11473 and the Volt Typhoon overlap. In October Talos named a separate cluster, UAT-11473, exploiting CVE-2026-20127 to install KeyDrift, a controller-resident framework for persistence, keying-material collection, a backdoor and intermediate command and control [17] (**Confirmed**). Talos assesses with high confidence that UAT-11473's infrastructure overlaps Volt Typhoon's "Silent Train" covert network; its post names no country, gives no activity dates and does not mention UAT-8616 [17] (**Confirmed**). That is an infrastructure overlap for a different cluster, not an attribution of UAT-8616 (**Inferred**). The SD-WAN precedent in ATT&CK is Volt Typhoon's Versa Director Zero Day Exploitation of June to August 2024 [24] (**Confirmed**); the lineage reading is ours (**Inferred**).

Mandiant's service provider. Mandiant saw unauthorized peering at a service provider from late 2025 to January 2026 and says it may have come from CVE-2026-20127 or -20182 while both were undisclosed; it confirms neither vector nor actor [16] (**Inferred** link).

The other clusters. The ten clusters that chained CVE-2026-20133, -20128 and -20122 from March are distinct from UAT-8616, and deployed web shells, Sliver, AdaptixC2 and XMRig miners [14] (**Confirmed**).

Part 4: impact and response

Victims. No victim is named. Canada's Cyber Centre says reported incidents involved rogue peers added to victims' SD-WAN configurations, followed by administrative access and persistence [9] (**Confirmed**). Talos says the broader edge-device targeting aims at high-value organizations including critical infrastructure [7]; UAT-11473 targeted space and satellite, defense and aerospace, and policy research organizations [17] (**Confirmed**). Censys counted about 600 internet-facing SD-WAN Managers on 27 February, mostly in the U.S., nearly a quarter also exposing port 22 or 830; that is exposure, not compromise [21] (**Confirmed** as Censys's measurement).

The vendor. Cisco credits the Australian Signals Directorate's Australian Cyber Security Centre with the report, lists no workarounds, and offers port restriction as a temporary mitigation, noting guardrails already in place in Cisco-hosted clouds [1] (**Confirmed**). The advisory went through four revisions in the eight months after first publication [1] (**Confirmed**).

CISA and KEV. Both February KEV entries carry a two-day due date, ransomware use Unknown, and a required action that points to ED 26-03 [4] (**Confirmed**). The directive required inventory and artifact collection by 23:59 ET on 26 February, patching by 17:00 ET on 27 February, two reports in March, log delivery to CLAW by 23 March, and a rebuild from patched images on any root compromise [12] (**Confirmed**). FedRAMP gave cloud providers the same 27 February deadline [20] (**Confirmed**). The April and May entries for

CVE-2026-20122, -20128, -20133 and -20182 carry the same ED 26-03 action [4] (**Confirmed**).

2026 KEV entries for Catalyst SD-WAN (catalog 2026.11.10)	Added
CVE-2026-20127, CVE-2022-20775	25 Feb
CVE-2026-20122, -20128, -20133	20 Apr
CVE-2026-20182	14 May
CVE-2026-20245	9 Jun
CVE-2026-20262	15 Jun
CVE-2026-76504	30 Sep

Source: the KEV catalog [4] (**Confirmed**).

The partners. CISA, NSA, ASD's ACSC, the Canadian Cyber Centre, NCSC-NZ and NCSC-UK issued the alert, with the hunt guide led by ASD's ACSC [8] (**Confirmed**). NCSC-NZ urged artifact collection, hunting, patching and hardening [10] (**Confirmed**), and NCSC-UK's chief technology officer said affected organizations should urgently investigate their exposure [19] (**Reported**).

Part 5: the defender and vulnerability-management view

SD-WAN controllers sit where a scanner rarely looks and where a compromise reaches every site at once (**Inferred**). Three facts change the usual patch-and-close routine: the bug was exploited before disclosure, the root step, in partners' assessment, likely used a 2022 CVE through a downgrade, and the affected product list grew in June [1] [7] (**Confirmed**).

Control	Where it meets the record
Patch both bypasses, not just the first	CVE-2026-20182 needs later builds [15]
Restrict ports 22 and 830 and isolate VPN 512	Cisco's mitigation and CISA's hardening [1] [11]
Validate every peering event against known System IPs	Cisco's IoC guidance; rogue peers in incidents [1] [9]
Alert on version downgrades followed by reboots	The downgrade-and-restore route to root [7]
Ship logs off the box, and watch for forwarding stopping	Logs and history removed; forwarding stopped [11]
Treat any root login as compromise and rebuild	ED 26-03 and its supplement [11] [12]
Track advisory revisions, not only the CVE	Validator added 16 Jun; UAT-11473 added 28 Oct [1]

What is overstated and what is understated

- **Overstated:** headlines saying the bug was "exploited in zero-day attacks since 2023" [18] (**Reported**) turn Talos's evidence window and CISA's "likely" into a dated vector that no primary supplies [7] [11] (**Inferred**). The March proof of concept billed as CVE-2026-20127 is, per Talos, a different bug [14] (**Confirmed**). Any reading of UAT-8616 as Volt Typhoon goes beyond the record [17] (**Inferred**).

- **Understated:** Cisco's "limited exploitation" sits beside a six-agency warning of global targeting [1] [8]; a second named actor used the same flaw [17]; the platform drew nine KEV entries in 2026 [4]; and Validator was added to the affected list almost four months after the emergency deadline [1] [12] (**Confirmed**). With no victims named, the known incidents are a floor, not a count (**Inferred**).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `technique_to_d3fend.jsonl`, `superseded_by.jsonl` and `data/weaknesses/` files [23] (**Demonstrated**). No source names ATT&CK ids; each row is this study's mapping (**Inferred**). Revoked ids were resolved through `superseded_by.jsonl`: Indicator Blocking (T1562.006) to T1685 and Clear Linux or Mac System Logs (T1070.002) to T1685.006 [23] (**Demonstrated**). SD-WAN controllers are not industrial control systems and no source describes an ICS effect, so no ATT&CK for ICS table applies.

Groups, software and campaigns

ATT&CK has no group object for UAT-8616 or UAT-11473 and no software object for KeyDrift, AdaptixC2 or XMRig [23] (**Demonstrated**), so none is bound.

Object	ATT&CK id	Relationship to this record
Sliver	S0633	Deployed by the ten clusters distinct from UAT-8616 (Talos, 14 May) [14]
Volt Typhoon	G1017	Infrastructure overlap with UAT-11473 only (Talos, 28 Oct) [17]; not bound to UAT-8616
Versa Director Zero Day Exploitation	C0039	Lineage only: Volt Typhoon's 2024 SD-WAN controller zero-day [24]

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1190	Exploit Public-Facing Application	Initial Access	CVE-2026-20127 exploitation (25 Feb); CVE-2026-20182 by UAT-8616 (14 May)	[1] [8] [14] [15]
T1068	Exploitation for Privilege Escalation	Privilege Escalation	Root via CVE-2022-20775 (25 Feb); zero-day CVE-2026-20245 (Mandiant, 24 Jun)	[7] [8] [16]
T1601.002	Downgrade System Image	Defense Impairment	Downgrade, exploit, restore (Talos, 25 Feb)	[7]
T1036	Masquerading	Stealth	Rogue peer appears as a legitimate SD-WAN component (CISA, 25 Feb)	[11]
T1136.001	Local Account	Persistence	Accounts created on the devices (Talos, 25 Feb)	[7]
T1070.009	Clear Persistence	Stealth	Accounts deleted after use (Talos, 25 Feb)	[7]
T1098.004	SSH Authorized Keys	Persistence, Privilege Escalation	Unauthorized keys on vmanage-admin (Talos and Cisco, 25 Feb)	[1] [7]
T1685.006	Clear Linux or Mac System Logs	Defense Impairment	Logs cleared or truncated (Talos and CISA, 25 Feb)	[7] [11]
T1070.003	Clear Command History	Stealth	Command history removed (Talos and CISA, 25 Feb)	[7] [11]
T1685	Disable or Modify Tools	Defense Impairment	Attempt to stop log forwarding (CISA, 25 Feb)	[11]
T1090.003	Multi-hop Proxy	Command and Control	UAT-8616 infrastructure linked to ORB networks (Talos, 14 May)	[14]
T1090	Proxy	Command and Control	KeyDrift intermediate command and control, UAT-11473 (Talos, 28 Oct)	[17]
T1552.004	Private Keys	Credential Access	KeyDrift keying-material collection, UAT-11473 (Talos, 28 Oct)	[17]
T1505.003	Web Shell	Persistence	Other clusters, not UAT-8616 (Talos, 14 May)	[14]
T1496.001	Compute Hijacking	Impact	XMRig miners, other clusters (Talos, 14 May)	[14]

Fit notes (**Inferred**): T1036 is written for artifacts rather than devices, so the rogue-peer fit is close but inexact. T1136.001 assumes the created accounts were local to the appliances. T1070.009 binds account deletion as cleanup. T1552.004 is the nearest fit for SD-WAN keying material. The NETCONF configuration change is part of the T1190 exploitation; interactive root sessions and lateral movement outside the SD-WAN are not bound because the sources do not say how they were done.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-287	Improper Authentication	CVE-2026-20127 (Cisco, NVD, KEV); CVE-2026-20182 (Cisco)	[1] [2] [4] [15]
CWE-25	Path Traversal: '/../filedir'	CVE-2022-20775 (Cisco, KEV)	[4] [6]
CWE-22	Improper Limitation of a Pathname to a Restricted Directory	CVE-2022-20775 (NVD)	[6]
CWE-282	Improper Ownership Management	CVE-2022-20775 (KEV)	[4]

CAPEC	Name	Via	Where it meets the record
CAPEC-115	Authentication Bypass	CWE-287	The peering authentication bypass [1]
CAPEC-151	Identity Spoofing	CWE-287	A forged handshake and a rogue peer posing as a component [11] [22] (**Inferred** fit)
CAPEC-126	Path Traversal	CWE-22	CVE-2022-20775 [6]
CAPEC-571	Block Logging to Central Repository	T1685	The attempt to stop log forwarding [11]
CAPEC-650	Upload a Web Shell to a Web Server	T1505.003	Other clusters' web shells [14]

The library relates no CAPEC to CWE-25, and the CAPEC it relates to CWE-282 does not meet this record [23] (**Demonstrated**). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Inbound Traffic Filtering, Network Traffic Filtering	T1190	Restricting ports 22 and 830; firewalling and VPN 512 isolation [1] [11]
User Geolocation Logon Pattern Analysis	T1190, T1090.003	Comparing login sources with configured System IPs [1] (**Inferred** fit)
Local Account Monitoring	T1136.001	Hunting created and deleted accounts [7]
Relay Pattern Analysis	T1090.003	ORB-network infrastructure [14]
File Integrity Monitoring	T1505.003	Other clusters' web shells [14]

CISA's rebuild from patched images and certificate replacement correspond to Restore Software and Certificate Rotation, which the library does not relate to these techniques [11] [12] [23] (**Inferred**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/cisco-sdwan-cve-2026-20127.json` (open in Navigator). Scores: 75 for behavior in a vendor advisory or government notice, 50 for a vendor threat-intelligence report, 25 for an inexact fit or other clusters' activity. Each technique's comment names its source numbers.

Cross-cutting themes

- **The edge is the front door, and the controller is the house key.** A controller bypass reaches every site the fabric serves; Threat Actors: China and the Edge Device Security Reference trace the same pattern on VPNs and firewalls (**Inferred**).
- **Old bugs come back through downgrades.** A 2022 fix did not protect a device that could be rolled back to a release still exposed to it [5] [7] (**Inferred**).
- **Disclosure and a public proof of concept invite a crowd.** Within weeks of a March proof of concept, ten other clusters were exploiting the platform's sibling bugs [14] (**Confirmed**).
- **Advisories are living documents.** Three revisions, a new product and a second actor arrived after the emergency deadline [1] [12] (**Confirmed**).

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	Cisco, cisco-sa-sdwan-rpa-EHchtZk (CVE-2026-20127), 25 Feb 2026, revision 2.1 of 28 Oct 2026, with its CSAF file	sec.cloudapps.cisco.com/.../cisco-sa-sdwan-rpa-EHchtZk	2026-11-11	Confirmed
2	NVD, CVE-2026-20127	nvd.nist.gov/vuln/detail/CVE-2026-20127	2026-11-11	Confirmed
3	CVE Program record CVE-2026-20127 (CNA Cisco)	cve.org/CVERecord?id=CVE-2026-20127	2026-11-11	Confirmed
4	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
5	Cisco, cisco-sa-sd-wan-priv-E6e8tEdF (CVE-2022-20775), 28 Sep 2022, revision 1.2 of 25 Feb 2026	sec.cloudapps.cisco.com/.../cisco-sa-sd-wan-priv-E6e8tEdF	2026-11-11	Confirmed
6	NVD, CVE-2022-20775	nvd.nist.gov/vuln/detail/CVE-2022-20775	2026-11-11	Confirmed
7	Cisco Talos, Active exploitation of Cisco Catalyst SD-WAN by UAT-8616, 25 Feb 2026	blog.talosintelligence.com/uat-8616-sd-wan/	2026-11-11	Confirmed
8	CISA, CISA and Partners Release Guidance for Ongoing Global Exploitation of Cisco SD-WAN Systems, 25 Feb 2026, revised 14 May 2026	cisa.gov/news-events/alerts/2026/02/25/...	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
9	Canadian Centre for Cyber Security, AL26-004, 25 Feb 2026	cyber.gc.ca/en/alerts-advisories/al26-004-...	2026-11-11	Confirmed
10	NCSC-NZ, Exploitation of Cisco SD-WAN appliances, 26 Feb 2026	ncsc.govt.nz/alerts/exploitation-of-cisco-sd-wan-appliances/	2026-11-11	Confirmed
11	CISA, Supplemental Direction ED 26-03: Hunt and Hardening Guidance for Cisco SD-WAN Systems, 25 Feb 2026	cisa.gov/news-events/directives/supplemental-direction-ed-26-03-...	2026-11-11	Confirmed
12	CISA, Emergency Directive 26-03, 25 Feb 2026, V1 11 Mar 2026	cisa.gov/news-events/directives/ed-26-03-...	2026-11-11	Confirmed
13	Cisco, cisco-sa-sdwan-authbp-qwCX8D4v, 25 Feb 2026, revision 1.3 of 22 Apr 2026	sec.cloudapps.cisco.com/.../cisco-sa-sdwan-authbp-qwCX8D4v	2026-11-11	Confirmed
14	Cisco Talos, Ongoing exploitation of Cisco Catalyst SD-WAN vulnerabilities, 14 May 2026	blog.talosintelligence.com/sd-wan-ongoing-exploitation/	2026-11-11	Confirmed
15	Cisco, cisco-sa-sdwan-rpa2-v69WY2SW (CVE-2026-20182), 14 May 2026	sec.cloudapps.cisco.com/.../cisco-sa-sdwan-rpa2-v69WY2SW	2026-11-11	Confirmed
16	Mandiant, Zero-Day Exploitation of Vulnerability (CVE-2026-20245) in Cisco Catalyst SD-WAN Manager, 24 Jun 2026	cloud.google.com/blog/topics/threat-intelligence/...	2026-11-11	Confirmed
17	Cisco Talos, Inside KeyDrift: Analyzing historical UAT-11473 activity on Cisco SD-WAN, 28 Oct 2026	blog.talosintelligence.com/uat-11473-keydrift/	2026-11-11	Confirmed
18	BleepingComputer, Critical Cisco SD-WAN bug exploited in zero-day attacks since 2023, 25 Feb 2026	bleepingcomputer.com/news/security/critical-cisco-sd-wan-bug-...	2026-11-11	Reported
19	The Record, report on the Five Eyes warning about Cisco SD-WAN exploitation, 25 Feb 2026	therecord.media/five-eyes-warn-hackers-exploit-cisco-sd-wan	2026-11-11	Reported
20	FedRAMP, NTC-0006, 25 Feb 2026	fedramp.gov/notices/0006	2026-11-11	Confirmed
21	Censys, CVE-2026-20127 advisory, 27 Feb 2026	censys.com/advisory/cve-2026-20127/	2026-11-11	Confirmed
22	Rapid7, CVE-2026-20127 root-cause analysis, 16 Jun 2026	rapid7.com/blog/post/ra-cve-2026-20127-analysis/	2026-11-11	Demonstrated
23	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `superseded_by.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), and `data/weaknesses/cwe.jsonl` and `capec.jsonl`	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Demonstrated
24	TeamStarWolf, C0039 and G1017 pages, Threat Actors: China, and ICS Attacks and Advisories 2024 to 2026	/mitre/campaigns/C0039.md	2026-11-11	Confirmed

Not opened, so not cited as sources: the ASD's ACSC-led hunt guide PDF (timed out), the ASD alert page (timed out), the NSA advisory PDF (blocked), and NCSC-UK's own alert page (not located).

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation.

This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Threat Actors: China, ICS Attacks and Advisories 2024 to 2026, The Year 2026 in Intrusions, Timeline
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Edge Device Security Reference, Vulnerability Management Reference, Vulnerability Prioritization Reference
- Groups and campaigns: G1017 Volt Typhoon, C0039 Versa Director Zero Day Exploitation
- Software: S0633 Sliver
- Techniques: T1190 Exploit Public-Facing Application, T1068 Exploitation for Privilege Escalation, T1601.002 Downgrade System Image, T1098.004 SSH Authorized Keys, T1685.006 Clear Linux or Mac System Logs, T1090.003 Multi-hop Proxy, T1552.004 Private Keys
- CAPEC: CAPEC-115, CAPEC-151, CAPEC-126, CAPEC-571, CAPEC-650
- Navigator layers, including this study's layer, cisco-sdwan-cve-2026-20127.json
- The Team Star Wolf Intelligence Hub
- All case studies